Content

History of Changes in documented informations **1**

1. System Change Policy **2**

Purpose and Scope 2

Background 2

Policy 2

2. Software Development Lifecycle Policy **3**

Purpose and Scope 3

Background 3

Policy 4

3. Workstation policy **6**

Purpose and Scope 6

Policy 6

Authorized software 7

4. Risk Assessment Policy **8**

Purpose and Scope 8

Background 8

Policy 8

History of Changes in documented informations

Date	Created by	ID	Version	Change
03.11.2020.	Juraj Malenica	1	0.1	Initial version
24.11.2020.	Juraj Malenica	2	1.0	First official release
21.06.2021	Juraj Malenica	3	1.1	Updated

Mindsmiths	Change Control & Configuration Management			
	ID	CCC	**Author**	Juraj Malenica
	Version	1.1	**Date**	21.06.2021.

1. System Change Policy

Purpose and Scope

This policy defines how changes to information systems are planned and implemented.

This policy applies to the entire information security program at Mindsmiths (i.e. to all information and communications technology, as well as related documentation).

All employees, contractors, part-time and temporary workers, service providers, and those employed by others to perform work for Mindsmiths, or who have been granted to Mindsmiths' information and communications technology, must comply with this policy.

Background

This policy defines specific requirements to ensure that changes to systems and applications are properly planned, evaluated, reviewed, approved, communicated, implemented, documented, and reviewed, thereby ensuring the greatest probability of success. Where changes are not successful, this document provides mechanisms for conducting post-implementation review such that future mistakes and errors can be prevented.

Policy

1. Any changes to the security architecture or customer data handling of a system must be formally requested in writing to Mindsmiths' Information Security Manager (ISM), and approved by the ISM.
2. Any changes to the staff dedicated to any project, like the termination or transfer, will be promptly communicated to the customer.
3. All change requests must be documented.
4. All change requests must be prioritized in terms of benefits, urgency, effort required, and potential impacts to Mindsmiths' operations.
5. All implemented changes must be communicated to relevant users.
6. Change management must be conducted according to the following procedure:
    a. Planning: plan the change, including the implementation design, scheduling, and implementation of a communications plan, testing plan, and roll-back plan.
    b. Evaluation: evaluate the change, including priority level of the service and

risk that the proposed change introduces to the system; determine the change type and the specific step-by-step process to implement the change.

c. Review: review the change plan amongst the ISM, Engineering Lead, and, if applicable, Business Unit Manager.
d. Approval: the ISM must approve the change plan.
e. Communication: communicate the change to all users of the system.
f. Implementation: test and implement the change.
g. Documentation: record the change and any post-implementation issues.
h. Post-change review: conduct a post-implementation review to determine how the change is impacting Mindsmiths, either positively or negatively.

2. Software Development Lifecycle Policy

Purpose and Scope

The purpose of this policy is to define requirements for establishing and maintaining baseline protection standards for company software, network devices, servers, and desktops.

This policy applies to all users performing software development, system administration, and management of these activities within Mindsmiths. This typically includes employees and contractors, as well as any relevant external parties involved in these activities (hereinafter referred to as “users”). This policy must be made readily available to all users.

This policy also applies to enterprise-wide systems and applications developed by Mindsmiths or on behalf of Mindsmiths for production implementation.

Background

The intent of this policy is to ensure a well-defined, secure and consistent process for managing the entire lifecycle of software and information systems, from initial requirements analysis until system decommission. The policy defines the procedure, roles, and responsibilities, for each stage of the software development lifecycle.

Within this policy, the software development lifecycle consists of requirements analysis, architecture and design, development, testing, deployment/implementation, operations/maintenance, and decommission. These processes may be followed in any form; in a waterfall model, it may be appropriate to follow the process linearly, while in an agile development model, the process can be repeated in an iterative fashion.

Mindsmiths	Change Control & Configuration Management			
	ID	CCC	**Author**	Juraj Malenica
	Version	1.1	**Date**	21.06.2021.

Policy

1. Mindsmiths' Software Development Life Cycle (SDLC) includes the following phases:
    a. Requirements Analysis
    b. Architecture and Design
    c. Testing
    d. Deployment/Implementation
    e. Operations/Maintenance
    f. Decommission
2. During all phases of the SDLC where a system is not in production, the system must not have live data sets that contain information identifying actual people or corporate entities, actual financial data such as account numbers, security codes, routing information, or any other financially identifying data. Information that would be considered sensitive must never be used outside of production environments.
3. The following activities must be completed and/or considered during the requirements analysis phase:
    a. Analyze business requirements.
    b. Perform a risk assessment. More information on risk assessments is discussed in the Risk Assessment Policy .
    c. Discuss aspects of security (e.g., confidentiality, integrity, availability) and how they might apply to this requirement.
    d. Review regulatory requirements and Mindsmiths' policies, standards, procedures and guidelines.
    e. Review future business goals.
    f. Review current business and information technology operations.
    g. Incorporate program management items, including:
        i. Analysis of current system users/customers.
        ii. Understand customer-partner interface requirements (e.g., business-level, network).
        iii. Discuss project timeframe.
    h. Develop and prioritize security solution requirements.
    i. Assess cost and budget constraints for security solutions, including development and operations.
    j. Approve security requirements and budget.
    k. Make “buy vs. build” decisions for security services based on the information above.
4. The following must be completed/considered during the architecture and design phase:
    a. Educate development teams on how to create a secure system.
    b. Develop and/or refine infrastructure security architecture.

   c. List technical and non-technical security controls.
   d. Perform architecture walkthrough.
   e. Create a system-level security design.
   f. Create high-level non-technical and integrated technical security designs.
   g. Perform a cost/benefit analysis for design components.
   h. Perform a design review, which must include, at a minimum, technical reviews of application and infrastructure, as well as a review of high-level processes.
   i. Describe detailed security processes and procedures, including: segregation of duties and segregation of development, testing and production environments.
   j. Design a general security test plan.
5. The following must be completed and/or considered during the development phase:
   a. Set up a secure development environment (e.g., servers, storage).
   b. Develop code for application-level security components.
   c. Install, configure and integrate the test infrastructure.
   d. Conduct unit testing and integration testing.
6. The following must be completed and/or considered during the testing phase:
   a. Set up a secure development environment (e.g., servers, storage).
   b. Perform a code and configuration review through both static and dynamic analysis of code to identify vulnerabilities.
   c. Test configuration procedures.
   d. Perform system tests.
   e. Conduct performance and load tests with security controls enabled.
7. The following must be completed and/or considered during the deployment phase:
   a. Perform integrity checking on system files to ensure authenticity.
   b. Require participation of at least two developers in order to conduct full-scale deployment to the production environment.
8. The following must be completed and/or considered during the operations/maintenance phase:
   a. Several security tasks and activities must be routinely performed to operate and administer the system, including but not limited to:
      i. Administering users and access.
      ii. Tuning performance.
      iii. Performing backups
      iv. Performing system maintenance (i.e., testing and applying security updates and patches).
   b. Operational systems must:
      i. Implement ongoing monitoring of systems and users to ensure detection of security violations and unauthorized changes.
      ii. Have a software application and/or hardware patching process that

is performed regularly in order to eliminate software bug and security problems being introduced into Mindsmiths' technology environment.

9. The following must be completed and/or considered during the decommission phase:
    a. Conduct unit testing and integration testing on the system after component removal.
    b. Conduct operational transition for component removal/replacement.
    c. Determine data retention requirements for application software and systems data.
    d. Assess and document how to mitigate residual application and infrastructure vulnerabilities.

3. Workstation policy

Purpose and Scope

This policy defines best practices to reduce the risk of data loss/exposure through workstations. This policy applies to all employees and contractors. Workstation is defined as the collection of all company-owned and personal devices containing company data.

Policy

1. Workstation devices must meet the following criteria:
    a. Operating system must be no more than one generation older than current, or it has to be an actively supported LTS generation
    b. Device must be encrypted at rest
    c. Device must be locked when not in use or when employee leaves the workstation
    d. Loss or destruction of devices should be reported immediately
2. Desktop & laptop devices
    a. Employees will be issued a desktop, laptop, or both by the company, based on their job duties. Contractors will provide their own laptops.
    b. Desktops and laptops must operate on macOS, Linux or Windows.

Authorized software

1. List of authorized software should be updated at least annually.
2. Installed software on company workstations should be checked at least annually.

Category	Software
Operating system	Windows 10, MacOS, Ubuntu-flavored Linux
Programming tools	Jetbrains-developed tools (PyCharm, Goland, Intellij...), VSCode, Git, Python3+, Golang1.14+, Java8+, GitKraken, Jupyter, MongoCompass, PgAdmin3, cutelog, htop, Terminator, Postman, Matlab, docker, docker-compose, npm, maven, pip, nodejs, Netica, Kontena Lens, Bayes Server
Security	OpenFortiVPN, FortiClient, Remmina, LastPass
Documents management	Google Docs, Google Drive File Stream, Google Sheets, Google Slides, Microsoft Excel, Microsoft OneNote, Microsoft Outlook, Microsoft PowerPoint, Microsoft Word, PDF Arranger, qpdfview, Adobe Acrobat Reader, Document Scanner, Celluloid
Data Analysis	Matlab, Maxqda12
Communication	Slack, Gmail, Telegram, Signal, Zoom, BlueJeans, Microsoft Teams, Skype, WhatsApp, GoToMeeting
Browser	Chrome, Firefox, Brave, Chromium, Safari
Media	Spotify, Rhythmbox, VLC, PulseEffects, Logic Pro X, Audacity
Other*	Gimp, Oracle VM Virtualbox, Startup disk creator, QuickTime Player, qBitTorrent, uTorrent, Calibre, Evince, Flameshot, Inkscape, Microsoft To Do, TeamViewer, AnyDesk, Trello, SimpleMind Lite, Pinterest, SMPlayer, GnomeCast, ImageMagick, GParted, PlayOnLinux,

HardwareProbe

*also includes software that comes preinstalled with the OS

4. Risk Assessment Policy

Purpose and Scope

The purpose of this policy is to define the methodology for the assessment and treatment of information security risks within Mindsmiths, and to define the acceptable level of risk as set by Mindsmiths' leadership. Risk assessment and risk treatment are applied to the entire scope of Mindsmiths' information security program, and to all assets which are used within Mindsmiths or which could have an impact on information security within it. This policy applies to all employees of Mindsmiths who take part in risk assessment and risk treatment.

Background

A key element of Mindsmiths' information security program is a holistic and systematic approach to risk management. This policy defines the requirements and processes for Mindsmiths to identify information security risks. The process consists of four parts: identification of Mindsmiths' assets, as well as the threats and vulnerabilities that apply; assessment of the likelihood and consequence (risk) of the threats and vulnerabilities being realized, identification of treatment for each unacceptable risk, and evaluation of the residual risk after treatment.

Policy

1. Risk Assessment
    a. The risk assessment process includes the identification of threats and vulnerabilities having to do with company assets.
    b. The first step in the risk assessment is to identify all assets within the scope of the information security program; in other words, all assets which may affect the confidentiality, integrity, and/or availability of information in Mindsmiths. Assets may include documents in paper or electronic form, applications, databases, information technology equipment, infrastructure, and external/outsourced services and processes. For each asset, an owner must be identified.
    c. The next step is to identify all threats and vulnerabilities associated with each asset. Threats and vulnerabilities must be listed in a risk assessment table. Each asset may be associated with multiple threats, and each threat may be associated with multiple vulnerabilities.

d. For each risk, an owner must be identified. The risk owner and the asset owner may be the same individual.

e. Once risk owners are identified, they must assess:

   i. Consequences for each combination of threats and vulnerabilities for an individual asset if such a risk materializes.

   ii. Likelihood of occurrence of such a risk (i.e. the probability that a threat will exploit the vulnerability of the respective asset).

f. The risk level is calculated by adding the consequence score and the likelihood score.

2. Risk Acceptance Criteria

   a. Risk values 0 through 2 are considered to be acceptable risks.

   b. Risk values 3 and 4 are considered to be unacceptable risks. Unacceptable risks must be treated.

3. Risk Treatment

   a. Risk treatment is implemented through the Risk Treatment Table. All risks from the Risk Assessment Table must be copied to the Risk Treatment Table for disposition, along with treatment options and residual risk.

   b. As part of this risk treatment process, the CEO and/or other company managers shall determine objectives for mitigating or treating risks. All unacceptable risks must be treated. For continuous improvement purposes, company managers may also opt to treat other risks for company assets, even if their risk score is deemed to be acceptable.

   c. Treatment options for risks include the following options:

      i. Selection or development of security control(s).

      ii. Transferring the risks to a third party; for example, by purchasing an insurance policy or signing a contract with suppliers or partners.

      iii. Avoiding the risk by discontinuing the business activity that causes such risk.

      iv. Accepting the risk; this option is permitted only if the selection of other risk treatment options would cost more than the potential impact of the risk being realized.

   d. After selecting a treatment option, the risk owner should estimate the new consequence and likelihood values after the planned controls are implemented.

4. Regular Reviews of Risk Assessment and Risk Treatment

   a. The Risk Assessment Table and Risk Treatment Table must be updated

when newly identified risks are identified.

b. The Risk Assessment process must be performed at least annually.

Consequence Level	Consequence Score	Description
Low	0	Loss of confidentiality, integrity, or availability will not affect the organization's cash flow, legal, or contractual obligations, or reputation.
Moderate	1	Loss of confidentiality, integrity, or availability may incur financial cost and has low or moderate impact on the organization's legal or contractual obligations and/or reputation.
High	2	Loss of confidentiality, integrity, or availability will have immediate and or/considerable impact on the organization's cash flow, operations, legal and contractual obligations,and/ or reputation.

Table 1: Description of Consequence Levels and Criteria

Likelihood Level	Likelihood Score	Description
Low	0	Either existing security controls are strong and have so far provided an adequate level of protection, or the probability of the risk being realized is extremely low. No new incidents are expected in the future.
Moderate	1	Either existing security controls have most provided an adequate level of protection or the probability of the risk being realized is moderate. Some minor incidents may have occurred. New incidents are possible, but not highly likely.

High	2	Either existing security controls are not in place or ineffective; there is a high probability of the risk being realized. Incidents have a high likelihood of occurring in the future.

Table 2: Description of Likelihood Levels and Criteria